

PRACTICAL-4

AIM: Implementation of MITM- attack using wireshark / network sniffers.

Wireshark or Ettercap

We'll need a client machine as well whose network traffic we will spoof and sniff to get cleartext submission of passwords from certain vulnerable websites.

Ettercap is GUI based tool built into Kali so need to download and install anything, so let's get started doing a MiTM attack with Ettercap.

Step #1: Start ettercap

Let's view the help file for ettercap by typing;

kali > ettercap -h

```

root@kali:~# ettercap -h

ettercap 0.8.0 copyright 2001-2013 Ettercap Development Team

Usage: ettercap [OPTIONS] [TARGET1] [TARGET2]

TARGET is in the format MAC/IP/PORTs (see the man for further detail)

Sniffing and Attack options:
-M, --mitm <METHOD:ARGS>    perform a mitm attack
-o, --only-mitm              don't sniff, only perform the mitm attack
-b, --broadcast              sniff packets destined to broadcast
-B, --bridge <IFACE>        use bridged sniff (needs 2 ifaces)
-p, --nopromisc              do not put the iface in promisc mode
-S, --nosslmitm             do not forge SSL certificates
-u, --unoffensive            do not forward packets
-r, --read <file>           read data from pcapfile <file>
-f, --pcapfilter <string>   set the pcap filter <string>
-R, --reversed               use reversed TARGET matching
-t, --proto <proto>         sniff only this proto (default is all)
    --certificate <file>    certificate file to use for SSL MiTM
    --private-key <file>    private key file to use for SSL MiTM

User Interface Type:
-T, --text                   use text only GUI
    -q, --quiet               do not display packet contents
    -s, --script <CMD>       issue these commands to the GUI
-C, --curses                 use curses GUI
-D, --daemon                 daemonize ettercap (no GUI)
-G, --gtk                    use GTK+ GUI

```

As you can see, ettercap has a significant help file for running it from a command line, but the only thing we need from here is the switch to run it in graphical mode. In the bottom line of the screenshot (not the bottom line of the actual help file as I have truncated it in the interest of space), you can see the `-G` switch. This after the command `ettercap` will launch the ettercap GUI.

kali > ettercap -G

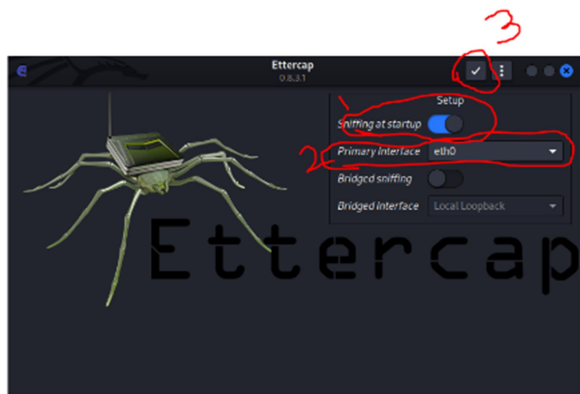
When we do, the ettercap GUI will start as seen below.



The first step in launching our MiTM attack is to start sniffing. Go to pulldown menu that says "Sniff" and click on "Sniffing at startup".

When we do that, it asking us what interface we want to use and defaults to eth0.

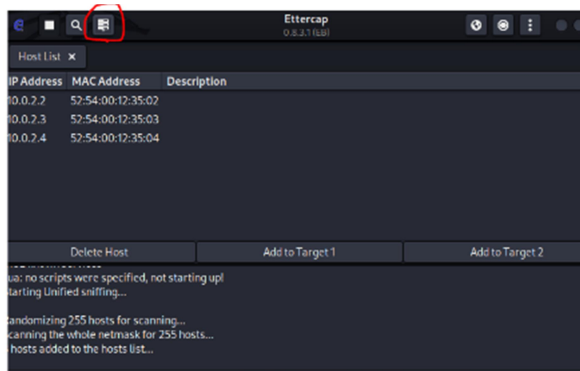
Then click on TICK mark



When we click "OK", ettercap launches it sniffing and loads its plugins. Our next step to find the hosts on the network. Click on the "Hosts" tab and you will see a menu that includes "Scan for Hosts". Click on it and ettercap will begin scanning the network for hosts.

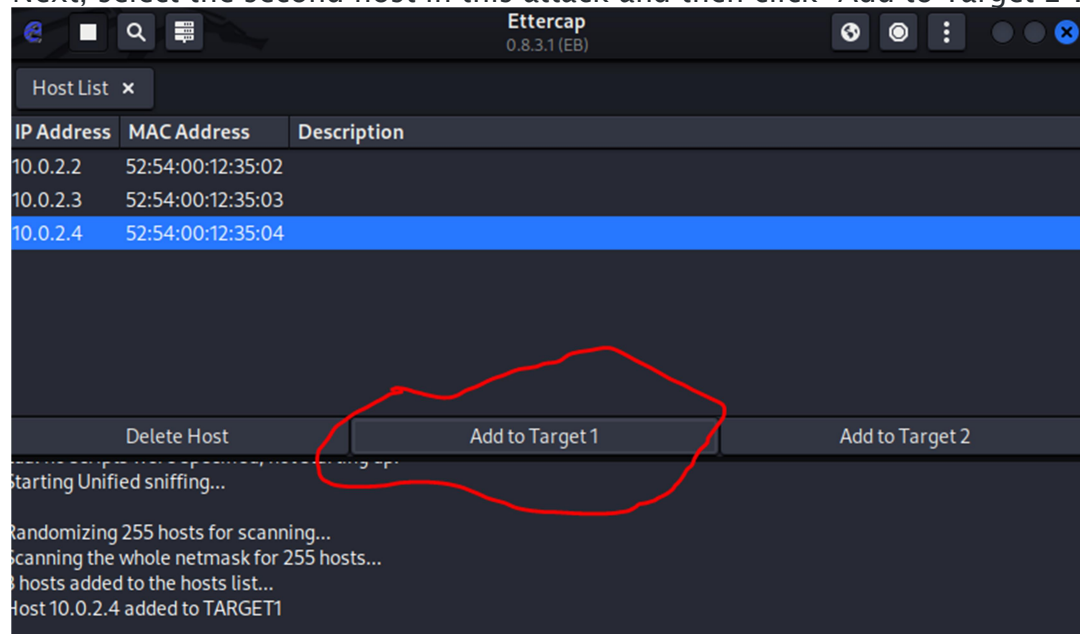


Now, using that same "Hosts" tab, click on "Hosts List". This will display all the hosts that ettercap has discovered on your network as seen in the screenshot below.

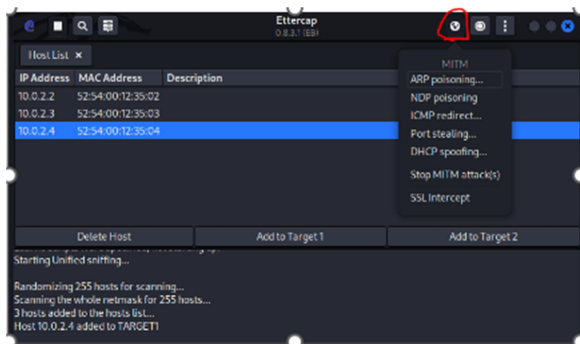


Now, select one of the hosts that will be the target of this attack in the window by clicking on it and then click on "Add to Target 1" at the bottom of the window. When you do so, ettercap will add that host as the first target in our MiTM attack as seen in the screenshot below.

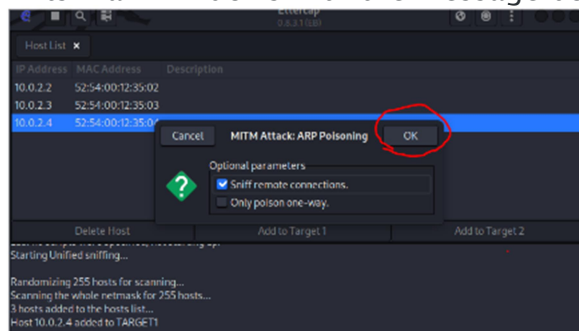
Next, select the second host in this attack and then click "Add to Target 2".



Finally, go to the menu above and click on MITM tab and the drop down menu will have a selection called "ARP Poisoning" as seen in the screenshot below.



Select it and it will open a pop window like below. Select "Sniff remote connections". When we press OK, ettercap will begin ARP poisoning and you will see ettercap respond in its main windows with the message below.



Now, we have successfully placed ourselves between the two targets systems and all their traffic must flow through us. This is where the fun begins as we can now delete, manipulate, impersonate and view all their traffic.

```
Host 192.168.1.116 added to TARGET1
Host 192.168.1.103 added to TARGET2

ARP poisoning victims:

GROUP 1 : 192.168.1.116 08:00:27:46:69:8D

GROUP 2 : 192.168.1.103 70:1A:04:F4:B9:D0
```

NOW open any browser on target IP address system and open any HTTP websites of LOGIN PAGE type your id and password then it will show output in ettercap output panel.

WIRESHARK:-

A basic setup is complete and victim network traffic will now pass through the attacker machine. To listen to these packets, we will use Wireshark ([To know about the basics of Wireshark, read our article here](#))

- Open up a new terminal and type wireshark. Go to the interface which is capturing all the data flow (here eth0) and start the capture.
- Filter out packets according to what you are looking for. For the purpose of this demo, the user is logging in to a vulnerable website DVWA which uses HTTP instead of the secure version HTTPS. Filter protocol as http and search for required data.

Disclaimer: This tutorial is purely intended for educational purposes and should not be misused.

- Right click on the packet and follow TCP stream to open up the data contained within. We can clearly obtain the login credentials of the user, that is the username and password.

MITM is one of the classic hacks and on a LAN connection, ARP spoofing is much preferred. Today there have been various measures to prevent such an attack by use of HTTPS, use of VPN and, strong WEP/WAP encryption on access points.